ORION ComplianceCore

STEP 2 | USER & ADMINISTRATOR GUIDE

26 October 2026 • Local review candidate • Production change pending approval

Start here

ComplianceCore connects what the organisation must do with its risks, safeguards, proof, checks and follow-up work. Begin with one real service and responsible people. Keep demonstration examples separate from actual records.

An obligation is a duty. A control is a safeguard. Evidence is the file showing what happened. A test checks whether a safeguard worked. A finding records a problem. Corrective action fixes its cause and checks that the fix worked.

Dashboard cards open duties needing review, tests awaiting review, actions awaiting effectiveness checks and policies waiting for readers. Your role determines what you see. A zero queue count is not a declaration of complete organisational compliance.

Open the compliance workflow panel on the relevant module page. Choose named people and source records. Type two or more letters to search a long picker list. Link an existing master instead of copying it into another module.

1. Agree the scope and reviewed duties

Complete organisation settings/scoping with services, locations, people, systems, information, suppliers and jurisdictions. In Frameworks open the assessment and record stakeholder consultation: who was consulted, named assets/services, responsibilities, boundaries, exclusions and supporting facts. Obtain the appropriate confirmation. Suggestions require review.

Open Obligations and official sources → Add obligation for review. Enter one specific duty, issuing authority, official source URL/edition, jurisdiction, sector, checked date and optional verified effective date. Decide applicability from organisational facts and record the reason, accountable person, deadline if verified, next review and related controls.

Save Draft while investigating or In review when ready. Another authorised person checks the source and approves or returns it; the author, owner/editor cannot self-approve. Revise record for source/business changes. The prior approved version remains under Reviewed source history.

Official starting points include https://ndpc.gov.ng/ and https://ndpc.gov.ng/download/nigeria-data-protection-act-2023, plus the organisation’s actual sector regulator. These are starting references, not a universal duties list. Record the current source edition, scope, effective date and human review decision.

2. Assess risks and choose safeguards

Open Risks and its framework worksheet. Name the actual asset/service, what could go wrong, likely cause and consequence. Review suggestions rather than accepting them automatically. Choose likelihood/impact using the displayed method and record existing safeguards, response, treatment owner/date and remaining-risk reasoning.

Link actual controls. Use Assess an existing risk in a worksheet when the risk already exists. Shared risks can link controls across frameworks; do not create duplicate risk masters. Download Excel for discussion; consultation, risks and scoring method are separate sheets.

Another authorised person reviews the remaining risk, selected controls, conditions and expiry. The owner/preparer cannot accept their own remaining risk. Changed facts require fresh confirmation/sign-off. A low score or accepted risk never removes a mandatory duty.

3. Draft, approve, publish and explain policies

Open Policy templates. Choose a relevant editable template or Word download. Tailor it to the organisation, replace bracketed placeholders, assign an owner/review date and link the appropriate context. An unedited template is not a publishable policy.

Save draft → submit for review → obtain independent approval → publish. Publication does not prove people have read it. In readership, select the published policy version, readers and due date. Each person opens the exact text and selects I have read this version; nobody acknowledges for another person.

For a new policy edition, repeat approval/publication and assign the new version. Old receipts remain historical evidence and cannot stand in for the current text.

4. Upload proof and test controls

In Evidence Hub upload the original file, use a clear title and link it to the actual source/control. Check confirmation and download. Replace through the version action rather than creating another evidence master. OCR may be queued or disabled; it does not replace the original.

Open Controls and Record a control test. Choose the safeguard, audit if relevant, period, expected outcome, sample, method, observed result and supporting files. Record pass/fail/exception honestly. Another authorised person reviews; tester/control owner cannot review their own work.

Changed safeguards, replaced/expired files and failed tests require a fresh review. A completed task, control status or meeting note is not a passed test. Reviewed failures create linked follow-up work.

Office documents remain downloadable. External Microsoft preview defaults off; if enabled, read and consent to the handoff before sending a document to it.

5. Audit, findings and corrective work

In Audits record scope, criteria, lead, dates and fieldwork. Use optional plan/report templates where helpful. Record an audit finding with facts, impact, severity, owner, due date and correction, linking its actual control/test when relevant.

Use an existing Task for corrective work. Open Corrective actions and effectiveness, select its source and explain root cause, immediate correction, prevention, effectiveness criteria and proof. Another person verifies effectiveness; approval completes the task, return sends it back to work and reopens the linked finding/incident.

Changed proof must be prepared and checked again. Review comments stay on the task. Close a finding only after linked corrective work is effective, with current closure proof and reasoning. Independently review the final current report before completing the audit. A later finding reopens a completed audit; changed report/closure proof needs fresh verification.

6. Incidents, suppliers and training

Report incidents promptly with awareness/detection time, facts, severity, affected services/data and responsibility. Record investigation, containment, root cause, remediation and lessons. Notification decisions record required/not required/submitted/pending, the applicable reviewed duty where needed, verified deadline/recipient, reason and receipt.

A separate authorised reviewer closes an incident. Save changed facts first, record a fresh notification decision, then request closure. Changed source/proof also requires a fresh decision. Do not assume all incidents have one reporting deadline.

Keep one Vendor master. Its questionnaire records service, data access, assurance, contracts, continuity, exceptions, current proof and next review. Another person reviews. For changed answers submit a new questionnaire version; changed/expired proof is flagged.

Create Training programmes and assign active people. A separate authorised verifier records actual attendance/assessment evidence and completion note. Assignment alone is not completion; changed proof is flagged.

7. Applicability, recurring work and management view

Finalise applicability after stakeholder scope, reviewed duties, risks and treatment choices. ISO 27001 uses a Statement of Applicability with inclusion/justified exclusion. Other families use their displayed coverage/assessment terminology and appropriate outcome; do not assume all lead to certification.

Complete displayed gates and obtain independent assessment review. Changes may reopen attention. Continue tests, policy/source reviews and follow-up work after sign-off. Use reports for the correct organisation/period and explain open risks and limitations.

Use source links and global search to trace duty → control → evidence version → test → finding → corrective task. Calendar/Notifications provide follow-up; check in-app notices even if email is not configured. Your administrator should state which external delivery channels actually passed acceptance tests.

Optional Word/CSV forms cover obligations, tests, audit plan/report, evidence requests, incidents, CAPA, vendors, conflicts, gifts, training, calendar and board reporting. Use existing controlled evidence/policies/approvals for completed declarations. These working forms do not automatically import into duplicate registers.

8. Examples — demonstration only

Hospital: consult clinical, records, IT and supplier stakeholders about a patient-record service. Review actual applicable duties, assess unauthorised access, approve a tailored policy and independently test a synthetic leaver sample. A failed removal becomes a finding and corrective task with retest proof.

School: agree the admissions/student-record scope with registrar, bursar, teachers and IT. Review actual licensing/privacy/contract duties. Assess record loss, select backup/access safeguards, verify staff training and review a synthetic restore sample. Keep overdue supplier actions visible until independently verified.

SME: scope payroll/invoicing with finance, management and provider. Review actual contractual/privacy duties, assess disclosure/outage, tailor an access policy, assign readers and review a monthly sample. Reuse one risk across relevant safeguards.

Regulated enterprise: assign source-review owners by applicable regulator/licence. Link approved duties to shared controls, risk decisions, policies and tests. Audit records findings and management response; independent reviewers verify correction. Management reporting states remaining exposure and due work. These are synthetic examples, not claims about real customers.

Administrator checklist and help

Check the selected organisation before working. Assign the least role needed and active named people. Existing eight roles/scopes remain. A read-only person cannot upload or approve. Personal security remains available when organisation administration is restricted.

Provide separate authorised preparers and reviewers. Define service ownership, remaining-risk acceptance authority, publication/closure approval, review dates and escalation responsibility. Do not grant privileges merely to bypass a valid self-review refusal.

Configure organisation details, branches/departments, evidence storage, source review, retention/legal holds, notification preferences and recovery ownership. Protect privileged/provisioning credentials in the secret manager. Provider/SSO configuration is environment-specific.

Read inline errors: correct the field/prerequisite, retain the entered work, reload a stale record to compare changes and complete missing evidence uploads. If access/review is refused, check role, assignment and independence. Ask support using request IDs/status, never a token or private document.

The Release and Runbook contains deployment, backup, rollback, support and unresolved acceptance items. These guides describe the Step 2 candidate; the live demo changes only after its approved deployment.